Jr.Pen 11.1. Phishing Basics

Task 1 - Introduction

Spam and phishing are the most common social engineering threats, with phishing posing a higher risk by tricking users into revealing sensitive data or installing malware. A single careless action, like clicking a malicious link, can compromise an entire network. Defenders must analyze email content to determine if messages are malicious and use that information to improve security and prevent future attacks.

A phishing campaign is a coordinated series of fraudulent messages, usually emails, designed to trick people into revealing sensitive information or installing malware. It often uses fake websites, spoofed senders, and social engineering to make the message look trustworthy.

Task 2 - The Email Address

where an email is composed of the following elements:

1. Username: User mailbox that identifies the specific recipient's mailbox on the email server
2. `@` symbol: Separates the username from the domain and tells the system where to route the email
3. Domain name: Specifies the mail server responsible for receiving the message

Answer the questions below

> Identify the domain used in the following email address: hatsalesman@tryhatme.com. tryhatme.com

Task 3 - Email Delivery

Each protocol has a specific role:

- **Simple Mail Transfer Protocol** (SMTP): Sends emails
- **Post Office Protocol** (POP3): Downloads emails to a device
- **Internet Message Access Protocol** (IMAP): Syncs emails across devices

When receiving emails, your email service will use either POP3 or IMAP, depending on how your mailbox is configured. Let's take a look at both of these protocols below:

POP3

- Emails are downloaded and stored on a single device
- Sent messages are stored on the single device from which the email was sent
- Emails can only be accessed from the single device to which the emails were sent
- Emails are typically removed from the server after download

IMAP

- Emails are stored on the server and can be downloaded to multiple devices
- Sent messages are stored on the server
- Syncs messages across multiple devices
- Emails remain on the server unless explicitly deleted

An Email's Journey: An email is sent from a user’s client to their mail server using SMTP. The server queries DNS to find the recipient’s mail server, then delivers the message over the internet. The recipient’s email client connects to their server and retrieves the email using POP3 or syncs it via IMAP.

Answer the questions below

> Which protocol is responsible for sending an email from a client to a mail server? SMTP

> Which service is used to look up the recipient domain’s mail server? DNS

> Bob wants to access his email from multiple devices, including his phone and laptop.
> Which protocol should he use? IMAP

Task 4 - Email Headers

An email consists of two main parts:

- **Email header**: Contains metadata about the message, such as sender and the servers involved in delivery
- **Email body**: Contains the actual message content, which may be plain text or HTML

Email Headers: In your VM, open up the `email1.eml` file in the `Email Samples` folder on your desktop.

1. **From**: The sender's email address
2. **To**: The receiver's email address
3. **Reply to**: Address where replies are sent (not required)
4. **Subject**: The email's subject line
5. **Date**: The time and date that the email was sent

Viewing the Message Source: Viewing the email source displays the full raw message, including all header fields and the email body, which may contain plain text or HTML.

1. Navigate to the View menu
2. Choose Message Source

Answer the questions below

> What is the full subject line of email1.eml? Return-Path



> View the message source of email1.eml using Thunderbird in your VM. What the IP address listed as the X-Originating-Ip? 43.255.56.161

Task 5 - Email Body

Emails are sent as text only or formatted in HTML. HTML supports elements such as images, links, and styling. Most email clients show you the rendered content.

Viewing HTML Source Code: By viewing the raw source, we can clearly see how these HTML elements are structured behind the scenes, giving us a closer look at links, images, and other embedded content that may not be immediately visible in the rendered view.

Reconstructing Attachments: When we inspect the source, we can identify several important headers associated with the attachment:

- **Content-Type** indicates the file type `application/pdf`
- **Content-Disposition** specifies that the file is an attachment and includes its filename
- **Content-Transfer-Encoding** shows that the file is `base64` encoded

Answer the questions below

> Open up the email2.txt file to view the source of an attachment. What is the Content-Type of the attachment? application/pdf

```
----------------------0917b1a36408bb427c44063070707099
Content-Type: application/pdf; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
Content-Transfer-Encoding: base64
Content-Disposition: attachment; filename="zmqpalgh.pdf"; name="zmqpalgh.pdf"
```

> What is the name of the attachment from the previous question? mzmqpalgh.pdf

> Decode the base64 string using either a PDF converter (opens in new tab) or CyberChef (opens in new tab). What is the hidden flag value? THM{BENIGN_PDF_ATTACHMENT}

Task 6 - Types of Phishing

- Spam(opens in new tab): Unsolicited bulk emails sent to a large number of recipients. A more malicious form of spam is often called malspam.
- Phishing(opens in new tab): Emails that impersonate a trusted entity to trick recipients into revealing sensitive information.
- Spear Phishing(opens in new tab): A targeted form of phishing aimed at a specific individual or organization, often using personalized information.

- Whaling(opens in new tab): A type of spear phishing that specifically targets high-level executives (CEO, CFO) to obtain sensitive data or financial access.
- Smishing(opens in new tab): Phishing attacks conducted via SMS or text messages, targeting users on mobile devices.
- Vishing(opens in new tab): Phishing attacks carried out through voice calls, where attackers use social engineering over the phone.

Anatomy of a Phishing Email

- **Spoofed From Address**: The sender's email is spoofed to appear as a trusted entity (`noreply@microsof.com`)
- **Urgent Subject or Message**: The email creates a sense of urgency ("Your account will be locked in 24 hours")
- **Brand Impersonation**: The email is designed to mimic a legitimate organization (logos or colors matching a real company)
- **Grammar & Spelling Issues**: The message may contain errors, though with AI these are now less common (awkward phrasing or unnatural wording)
- **Generic Content**: The message lacks personalization ("Dear Customer" instead of your name)
- **Hidden or Shortened Links**: Hyperlinks may disguise their true destination (`bit.ly/secure-login`)
- **Malicious Attachments**: Attachments are included and disguised as legitimate files (`invoice.pdf.exe`)

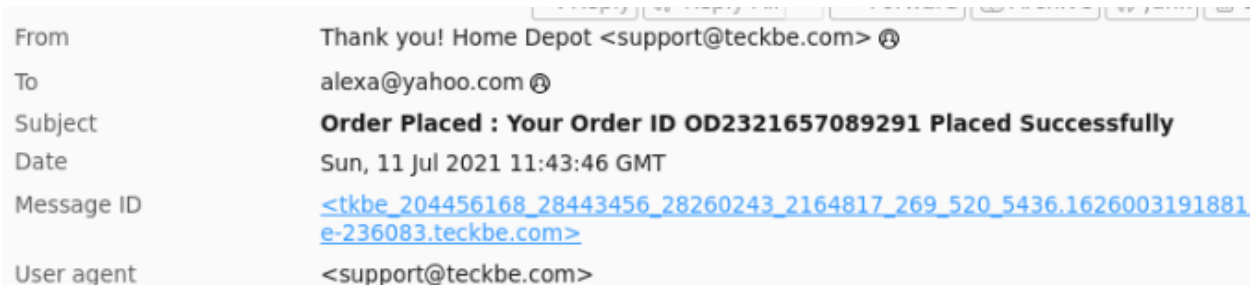
Safe Analysis: Hyperlinks(opens in new tab) and IP addresses(opens in new tab) should be **defanged**. Defanging makes URLs, domains, or email addresses unclickable to prevent accidental clicks that could lead to a security breach.

- Original URL: `http://www.suspiciousdomain.com`
- Defanged URL: `hxxp[://]www[.]suspiciousdomain[.]com`

Investigation: Let's put all of this knowledge to the test and analyze the email titled `email3.eml` within the virtual machine to answer the questions below.

Answer the questions below

> Which reputable organization is being spoofed in this phishing attempt? Home Depot



From	Thank you! Home Depot <support@teckbe.com>
To	alexa@yahoo.com
Subject	**Order Placed : Your Order ID OD2321657089291 Placed Successfully**
Date	Sun, 11 Jul 2021 11:43:46 GMT
Message ID	<tkbe_204456168_28443456_28260243_2164817_269_520_5436.1626003191881 e-236083.teckbe.com>
User agent	<support@teckbe.com>

> What is the sender's email address? support@teckbe.com

> Inspect the email message source. What is the defanged (opens in new tab) X-Originating-IP? 103[.]234[.]236[.]83

> Continue analyzing the email message source. Which mail server generated the Authentication-Results header? atlas102.free.mail.gq1.yahoo.com

Task 7 - Conclusion

Examined common phishing techniques and applied your knowledge to analyze real-world examples, identifying attacker intent.

It’s also important to understand Business Email Compromise (BEC), a type of attack where an adversary gains access to a legitimate internal email account and uses it to trick others into performing unauthorized or fraudulent actions.

Business Email Compromise (BEC) is an attack where an adversary gains access to a legitimate email account and uses that trusted identity to manipulate others into taking unauthorized actions, often involving money or sensitive data. Unlike noisy spam, BEC typically relies on trust and convincing business-like communication to evade suspicion.